

EDR'ye GİRİŞ

[Kaynak](#)

İÇERİK

1. Endpoint Detection and Response (EDR) Mimarisi ve Temel Bileşenleri
2. Antivirüsün Ötesi: Neden EDR'a İhtiyacımız Var?
3. EDR (Endpoint Detection and Response) Çalışma Mantığı ve Mimari İncelemesi
4. EDR (Endpoint Detection and Response) Telemetrisi
5. EDR: Tespit ve Müdahale Yetenekleri (Detection and Response Capabilities)

Endpoint Detection and Response (EDR) Mimarisi ve Temel Bileşenleri

Geleneksel ağ güvenliği (Network Security) yaklaşımları, kurumların dijital varlıklarını korumak için genellikle ağın dış sınırlarına (perimeter) yerleştirilen güvenlik duvarları (Firewall) ve saldırı tespit/önleme sistemleri (IDS/IPS) üzerine inşa edilmiştir. Ancak, Uzaktan Çalışma (Remote Work) modelinin hızla benimsenmesiyle birlikte son kullanıcı cihazları (endpoints) bu güvenli ağ sınırlarının dışına çıkmıştır. Cihazların güvensiz ağlarda (örneğin ev ağları veya ortak Wi-Fi alanları) çalışmaya başlaması, geleneksel ağ tabanlı korumaları etkisiz kılmış ve doğrudan uç noktanın üzerinde çalışan, sürekli izleme ve gelişmiş tehdit tespiti yapabilen bir güvenlik çözümüne ihtiyacı doğurmuştur.

Endpoint Detection and Response (EDR), cihazın bulunduğu fiziksel veya mantıksal ağdan bağımsız olarak, işletim sistemi seviyesinde derinlemesine (deep-level) izleme, tespit ve müdahale yetenekleri sunan nihai uç nokta güvenlik çözümüdür.

Sektörde yaygın olarak kullanılan ve mimarileri temelde aynı ajan tabanlı (agent-based) yapıya dayanan önde gelen EDR çözümleri şunlardır:

- CrowdStrike Falcon
- SentinelOne ActiveEDR
- Microsoft Defender for Endpoint
- OpenEDR (Açık kaynaklı alternatif)
- Symantec EDR

EDR'in Üç Temel Sütunu (The Three Pillars of EDR)

Bir EDR çözümünün gücü, sahip olduğu üç temel çekirdek yetenek etrafında şekillenir: **Visibility (Görünürlük)**, **Detection (Tespit)** ve **Response (Müdahale)**.



EDR

Visibility



Detection

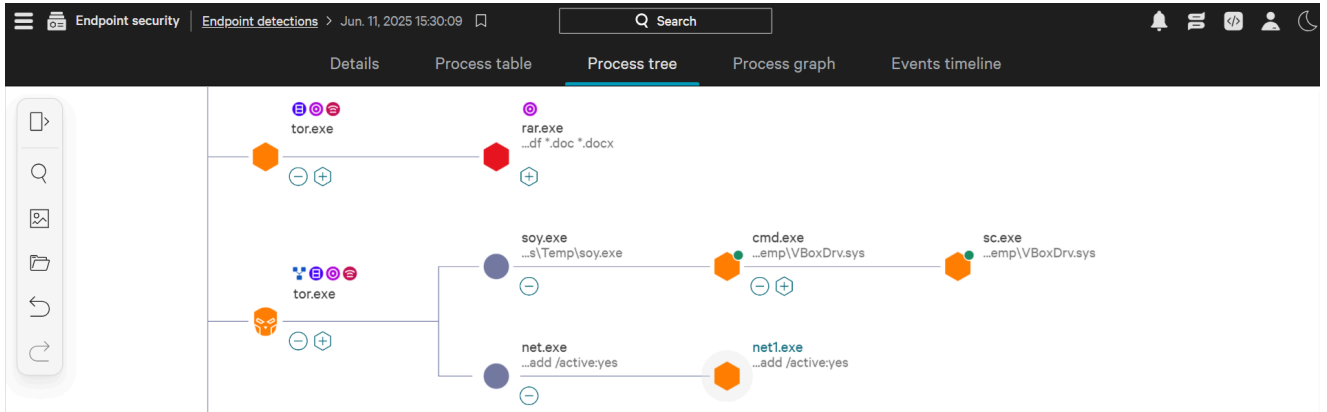


Response



1. Visibility (Görünürlük) - Analizin Temeli

Başarılı bir siber güvenlik analizi, sistemde gerçekleşen olayların ne kadar detaylı görülebildiğine bağlıdır. EDR'ı geleneksel antivirüs (AV) çözümlerinden ayıran en kritik özellik, sunduğu muazzam görünürlük seviyesidir. EDR ajanı, işletim sistemi çekirdeğine (kernel) yakın seviyede çalışarak aşağıdaki verileri sürekli olarak toplar ve **Threat Hunting (Tehdit Avcılığı - ağda gizlenmiş tehditleri proaktif olarak arama)** süreçleri için tarihsel olarak (historical data) saklar:



- **Process Modifications (Süreç Değişiklikleri):** Hangi sürecin (process) ne zaman başlatıldığı, hangi parametreleri aldığı ve hangi süreçleri doğurduğu (process tree).
- **Registry Modifications (Kayıt Defteri Değişiklikleri):** Zararlı yazılımların kalıcılık (persistence) sağlamak için işletim sisteminin kayıt defterinde yaptığı değişiklikler.
- **File and Folder Modifications (Dosya ve Klasör Değişiklikleri):** Dosya oluşturma, silme veya şifreleme (özellikle Ransomware davranışları) eylemleri.
- **Network Connections (Ağ Bağlantıları):** Süreçlerin dış dünya veya iç ağdaki hangi IP adresleri ve portlarla iletişim kurduğu.

Bir EDR (örneğin CrowdStrike Falcon) arayüzünde, bu görünürlük genellikle analiste bir **Process Tree (Süreç Ağacı)** olarak sunulur.

```
[Süreç Ağacı Simülasyonu - Telemetri Çıktısı]
explorer.exe (PID: 1420)
├─ outlook.exe (PID: 3012)
│   └─ winword.exe (PID: 4500) [Dosya: invoice_Q3.doc]
│       └─ cmd.exe (PID: 5120) /c "powershell.exe -nop -w hidden -enc
JABzAD0ATgBLAHcALQBP..."
│           └─ powershell.exe (PID: 6032) [Ağ Bağlantısı:
192.168.1.100:4444 -> 10.10.50.5:80]
```

Çıktının Mantıksal Analizi: Yukarıdaki çıktı sadece bir log değil, bir saldırı zincirinin anatomisidir. `explorer.exe` (Windows masaüstü ortamı) normal bir şekilde `outlook.exe` 'yi başlatmıştır. Kullanıcının e-postadaki sahte bir faturayı (`invoice_Q3.doc`) açmasıyla `winword.exe` çalışmıştır. İşin kırılma noktası ve EDR'in görünürlüğünün parladığı yer tam burasıdır: Bir Word uygulamasının normal şartlarda `cmd.exe` (Komut İstemi) başlatması beklenen bir davranış (baseline) değildir. `cmd.exe` üzerinden gizli parametrelerle (`-nop -w hidden -enc`) Base64 ile şifrelenmiş bir `powershell.exe` çağrılmış ve dış bir IP adresine ağ bağlantısı yapılmıştır (Muhtemelen bir Reverse Shell). EDR, bu hiyerarşik bağı eksiksiz sunarak analistin kök nedeni (Root Cause) saniyeler içinde tespit etmesini sağlar.

2. Detection (Tespit Mekanizmaları)

Geleneksel AV'ler yalnızca daha önceden bilinen zararlı yazılımların hash değerlerine veya kod bloklarına (Signature-based - İmza tabanlı) odaklanır. EDR ise bunu kapsamakla birlikte asıl gücünü **Behavior-based (Davranış tabanlı)** tespit mekanizmalarından alır.

- **Machine Learning & Baseline Deviation:** EDR, makine öğrenimi algoritmaları kullanarak o uç noktanın "normal" çalışma davranışını (baseline) öğrenir. Örneğin; Muhasebe departmanındaki bir kullanıcının aniden `vssadmin.exe` (Shadow Copy silme aracı) çalıştırması bir sapmadır (deviation) ve anında işaretlenir (flagged).
- **Fileless Malware (Dosyasız Zararlı Yazılım) Tespiti:** Geleneksel AV'lerin en büyük kör noktası diske dosya yazmadan doğrudan RAM (Bellek) üzerinde çalışan zararlılardır. EDR, bellek içi enjeksiyonları (memory injection) ve PowerShell/WMI gibi "Living off the Land" (Sistemdeki meşru araçları kötüye kullanma) tekniklerini anında yakalar.
- **Custom IOC (İhlal Göstergesi) Entegrasyonu:** Analistler, yeni bir tehdit istihbaratı aldıklarında (örneğin zararlı bir IP adresi veya dosya hash'i), bunu doğrudan EDR sistemine besleyerek tüm ağda saniyeler içinde tarama yapabilirler.
- **MITRE ATT&CK Eşleşmesi:** Modern EDR sistemleri, tespit edilen her anormalliği doğrudan MITRE framework'ündeki **Tactic (Saldırganın Amacı)** ve **Technique (Bunu Nasıl Yaptığı)** ile eşleştirir. Bu, SOC (Security Operations Center) analistine tespitin içeriği hakkında anında bağlam (context) kazandırır.

Endpoint security

Endpoint detections

Search

Detections 23 results (243 total)

Search detections

Severity

Time

Status

Tactic

Technique

Tags

Command line

Grouping tags

Add/remove filters +

Clear all

List is up to date

Aggregate detections Off

Group by

Sort by Time: Newest to oldest

Severity

Detect time

Name

Attributes

Aug. 12, 2025

Severity

High

Detect time

09:00:44

Process on host

powershell.exe on SRV-01 by Administrator

Tactic via technique

Defense Evasion via

Command line

"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -WIN...

Aug. 10, 2025

Severity

High

Detect time

15:34:51

Process on host

Setup.exe on LPT-12766 by j.adams

Tactic via technique

Machine Learning ...

Command line

"C:\Users\j.adams\Downloads\Photoshop 26.3 (Cracked)\Setup.exe"

Severity

Low

Detect time

14:01:45

Process on host

cmd.exe on LPT-10075 by k.smith

Tactic via technique

Malware via Adware

Command line

"C:\WINDOWS\system32\cmd.exe" /d /c TIMEOUT 5 & cmd /d /c del "C:..."

Severity

Low

Detect time

14:01:45

Process on host

appbundle.exe on LPT-10075 by k.smith

Tactic via technique

Malware via Adware

Triggering file

appbundle.exe

Hostname

LPT-10075

User name

k.smith

3. Response (Müdahale ve Yanıt)

Sadece tespit etmek yeterli değildir; tehdidi izole etmek ve etkisiz hale getirmek gerekir. EDR konsolu, analiste siber olaya anında müdahale etme yetkisi (empowerment) verir. Fiziksel olarak dünyanın neresinde olursa olsun, internete bağlı bir uç noktada EDR üzerinden şu kritik eylemler gerçekleştirilebilir:

- **Network Isolation (Ağ İzolasyonu):** Zararlı yazılım bulaşmış cihazın (örneğin bir Ransomware vakasında yatay hareketin / lateral movement engellenmesi için) ağ ve internet erişimi anında kesilir. İşletim sistemi seviyesindeki firewall kuralları ezilir ve cihazın SADECE EDR yönetim sunucusuyla iletişim kurmasına izin verilir.
- **Process Termination (Süreç Sonlandırma):** Tespit edilen zararlı sürecin ağacındaki tüm süreçler bellekten düşürülür (kill process).
- **File Quarantine (Dosya Karantinası):** Zararlı olduğu tespit edilen dosya şifrelenerek kullanıcının veya sistemin erişemeyeceği güvenli bir alana taşınır.
- **Remote Shell / Execution:** Analist, arka planda kullanıcıyı rahatsız etmeden cihaza güvenli bir uzak terminal bağlantısı kurarak detaylı komut satırı incelemeleri yapabilir veya özel müdahale scriptleri çalıştırabilir.

Falcon Real Time Response

hq-prd-website | Console

Search

hq-prd-website

Linux

Connected (Session start: Aug. 12, 2025 20:05:12)

End session

cat

Read a file from disk and display as ASCII.

cd

Change the current working directory.

clear

Clear screen.

cp

Copy a file or directory.

encrypt

Encrypt a file with AES-256.

env

Print out the environment.

Run commands

Edit & run scripts

```
1 grep -REI 'base64_decode|eval|assert|shell_exec|system|passthru|exec|popen|proc_open' /var/www/html
```

Arguments

Enter arguments

Save as

Run script

ÖNEMLİ (EDR'in Sınırları): EDR'in sunduğu bu gelişmiş görünürlük, tespit ve müdahale kapasitesi ne kadar güçlü olursa olsun, EDR **sadece host tabanlı (uç nokta) bir güvenlik çözümüdür**. Cihazın işletim sistemine veya belleğine dokunmayan, tamamen ağ trafiği üzerinde gerçekleşen tehditleri (örneğin bir Switch üzerindeki ARP Spoofing saldırısı, pasif ağ dinleme/sniffing veya network seviyesindeki Man-in-the-Middle saldırıları) tek başına tespit edemez. Bu tür tehditler için Network Detection and Response (NDR) çözümlerine ve her ikisini birleştiren XDR (Extended Detection and Response) mimarilerine ihtiyaç duyulur.

Antivirüsün Ötesi: Neden EDR'a İhtiyacımız Var?

Siber güvenlik mimarisinde uç nokta (endpoint) güvenliği tasarlanırken en sık karşılaşılan kavram yanılgılarından biri, geleneksel Antivirüs (AV) çözümlerinin modern tehditlere karşı yeterli olacağı düşüncesidir. Hem AV hem de **Endpoint Detection and Response (EDR - Uç Nokta Tespiti ve Yanıtı)** çözümleri temelde cihazı korumayı hedefler; ancak aralarındaki mimari ve analitik derinlik farkı, başarılı bir savunma ile yıkıcı bir siber ihlal arasındaki çizgiyi belirler.

Bu farkı kavramak için bir havalimanı güvenliği analojisi kurabiliriz: Geleneksel AV çözümleri, havalimanının pasaport kontrol (gümrük) noktasıdır. Gelen kişilerin (dosyaların) pasaportlarını, kendi veritabanındaki bilinen suçlular (zararlı yazılım imzaları / hash değerleri) listesiyle karşılaştırır. Eşleşme varsa girişi engeller. Ancak, daha önce hiç suç işlememiş, veritabanında kaydı olmayan (Zero-day veya özel olarak derlenmiş zararlılar) profesyonel bir hırsız bu kontrol noktasından rahatlıkla geçebilir.

İşte EDR, havalimanının içine yerleştirilmiş, yüzlerce CCTV kamerasını izleyen ve hareket sensörlerini analiz eden iç güvenlik personelidir. Bir kişi (süreç/process) pasaport kontrolünü geçmiş olsa bile; "Bu kişi neden yetkisiz personel alanına girmeye çalışıyor?", "Neden çantasını bırakıp kaçıyor?" gibi **davranışsal anormallikleri (Behavioral Anomalies)** sürekli izler, korelasyon kurar ve tehlike anında anında müdahale eder.

Geleneksel AV **Signature-based detection** (İmza tabanlı tespit - bilinen zararlı yazılımların hash veya kod yapılarının statik veritabanıyla karşılaştırılması) yaparken, EDR süreçlerin, belleğin ve ağ bağlantılarının davranışlarını izler ve kurum çapında geniş bir görünürlük sağlar.

Modern Bir Saldırı Zincirinin Anatomisi: AV ve EDR Karşılaştırması

Gelişmiş bir tehdit aktörünün, uç noktayı ele geçirmek için izlediği adımları ve bu adımlara karşı AV ile EDR'ın verdiği tepkileri teknik bir yaklaşımla inceleyelim.

Saldırı Senaryosu Başlangıcı: Kullanıcı, içerisinde zararlı bir makro (**VBA script**) barındıran bir Word belgesini oltalama (**Phishing**) e-postası üzerinden indirir ve açar.

Adım 1: Dosyanın İndirilmesi

- **AV Tepkisi:** İndirilen belgenin hash değeri daha önce bilinen bir zararlıya ait değilse

(imza eşleşmesi yoksa), AV hiçbir işlem yapmaz ve dosyanın diske yazılmasına izin verir.

- **EDR Tepkisi:** Dosya indirme aktivitesini (File Write olayı) detaylıca loglar, dosyanın nereden geldiğini kaydeder ve süreci izlemeye başlar.

Adım 2: Belgenin Çalıştırılması

- **AV Tepkisi:** Kullanıcı dosyayı açtığında, işletim sistemi meşru bir uygulama olan `winword.exe` 'yi (Microsoft Word) başlatır. AV için `winword.exe` güvenilir bir yazılımdır, bu nedenle eyleme izin verir.
- **EDR Tepkisi:** `winword.exe` 'nin çalışma anını (Process Creation) ve bu sürecin başlattığı argümanları kayıt altına alır.

Adım 3: Makronun Tetiklenmesi ve PowerShell'in Çağırılması

Arka planda sessizce çalışan zararlı makro, sistemde komut çalıştırmak için `powershell.exe` 'yi başlatır.

- **AV Tepkisi:** Makro kodu statik olarak zararlı bir imza barındırmıyorsa AV bunu kaçıırır.
- **EDR Tepkisi: ÖNEMLİ:** EDR, burada çok kritik bir **Parent-Child Relationship (Ebeveyn-Çocuk Süreç İlişkisi)** anormalliği tespit eder. Bir kelime işlemci uygulamasının (`winword.exe`), bir sistem yönetim kabuğunu (`powershell.exe`) başlatması normal bir davranış (baseline) değildir. EDR bu durumu anında şüpheli olarak işaretler (Flag).

```
# EDR'in Görselleştirdiği Mantıksal Süreç Ağacı (Process Tree)
[+] explorer.exe (PID: 2044) - Normal Masaüstü Süreci
└─ [+] winword.exe (PID: 3102) - Meşru Uygulama (Tetiklenen Dosya:
invoice.doc)
    └─ [!] powershell.exe (PID: 4892) - ŞÜPHELİ EBEVEYN-ÇOCUK İLİŞKİSİ
```

Yukarıdaki süreç ağacında, EDR'in saldırıyı tespit ettiği kırılma noktası görülmektedir.

`winword.exe` 'nin altında `powershell.exe` 'nin çalışması, tipik bir makro tabanlı ilk erişim (Initial Access) tekniğidir.

Adım 4: Komut Gizleme (Obfuscation) ve İkinci Aşama Yük (Payload) İndirme

Zararlı makro, güvenlik çözümlerini atlatmak için şifrelenmiş veya karmaşılaştırılmış (Obfuscated) bir PowerShell komutu çalıştırarak asıl zararlı yazılımı (Second-stage **Payload**) dışarıdan indirir.

- **AV Tepkisi:** Geleneksel AV'ler, özellikle bellekte (RAM) çalışan ve diske yazılmayan karmaşık PowerShell scriptlerini (Fileless malware) analiz edemez.
- **EDR Tepkisi:** EDR (genellikle AMSI - Antimalware Scan Interface entegrasyonu ile), PowerShell'in bellekte çözdüğü nihai komutu görür ve karmaşılaştırılmış (obfuscated) kod yürütme girişimini anında tespit eder.

Adım 5: Süreç Enjeksiyonu (Process Injection)

İndirilen Payload, kendini gizlemek için işletim sisteminin meşru ve sürekli çalışan kritik servislerinden biri olan `svchost.exe` 'nin

bellek alanına kendini enjekte eder (**Process Injection - Süreç Enjeksiyonu: Zararlı kodun, meşru bir sürecin bellek alanına yerleşerek onun yetkilerini kullanması ve kendini gizlemesi taktiği**).

- **AV Tepkisi:** AV, `svchost.exe` 'yi Microsoft tarafından imzalanmış güvenilir bir sistem süreci olarak gördüğü için, bellekte yaşanan bu enjeksiyonu izleyemez ve tepkisiz kalır.
- **EDR Tepkisi:** EDR, çekirdek (kernel) seviyesinde API çağrılarını izlediği için, bir sürecin başka bir sürecin bellek alanına (örneğin `WriteProcessMemory` veya `CreateRemoteThread` fonksiyonları ile) kod yazdığını tespit eder ve "Process Injection" alarmını üretir.

Adım 6: Komuta ve Kontrol (C2) Bağlantısı Ele geçirilen `svchost.exe` , saldırganın sunucusuna dışarı doğru (outbound) bir ağ bağlantısı açarak sisteme uzaktan erişim (**Reverse Shell**) sağlar.

- **AV Tepkisi:** AV'lerin ağ seviyesinde görünürlüğü yoktur, dolayısıyla bu bağlantıyı tamamen kaçırır. Nihai olarak AV bu makineyi "Temiz" olarak raporlamaya devam eder.
- **EDR Tepkisi: DİKKAT:** Meşru bir sistem servisi olan `svchost.exe` 'nin, bilinmeyen bir dış IP adresine şüpheli bir ağ bağlantısı başlatması kritik bir anormalliktir. EDR, `winword.exe` 'den başlayıp dış ağ bağlantısına kadar uzanan tüm bu zinciri birleştirir.

Sonuç ve EDR'in Gücü: Bu senaryonun sonunda, geleneksel AV makineyi güvenli sanarken; EDR, analiste saldırının **kök nedenini (Root Cause)**, tüm **saldırı zincirini (Attack Chain)** ve MITRE ATT&CK eşleşmelerini içeren zenginleştirilmiş bir alarm sunar. Daha da önemlisi, analist EDR konsolu üzerinden tek bir tıklamayla makineyi ağdan izole edebilir (Network Isolation) veya zararlı süreci bellekten sonlandırabilir (Kill Process).

EDR (Endpoint Detection and Response) Çalışma Mantığı ve Mimari İncelemesi

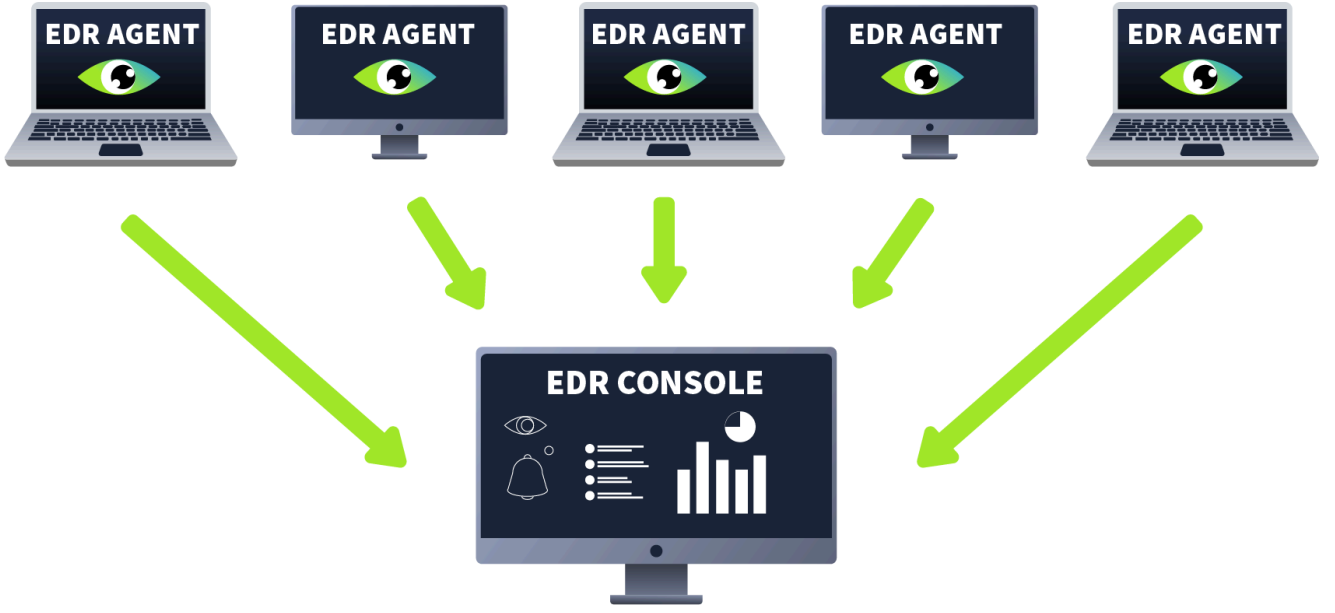
Uç Nokta Ajanları (Agents / Sensors) ve Telemetri Toplama

Bir EDR çözümünün temeli, izlenmek istenen her bir uç noktaya (sunucu, istemci, mobil cihaz) kurulan **Agent** (Ajan) veya **Sensor** (Sensör) adı verilen hafif yazılımlara dayanır. Bu ajanlar, işletim sisteminin çekirdek (kernel) veya kullanıcı (user) alanında çalışarak EDR'ın "gözü ve kulağı" işlevini görürler.

Ajanların temel görevi, işletim sistemi üzerinde gerçekleşen her türlü aktiviteyi (yeni bir sürecin başlaması, kayıt defteri değişiklikleri, ağ bağlantıları, dosya okuma/yazma işlemleri) **Telemetry** (Telemetri - cihazdan toplanan ham izleme verisi) olarak toplamak ve gerçek zamanlı olarak merkezi EDR konsoluna iletmektir.

ÖNEMLİ: Ajanlar sadece pasif veri toplayıcılar değildir. Kendi içlerinde barındırdıkları hafif imza veritabanları ve temel davranışsal analiz yetenekleri sayesinde, ağ bağlantısı kopsa bile veya merkezi konsolla iletişim kurulamasa dahi, bariz zararlı aktiviteleri (örneğin bilinen

bir fidye yazılımı imzası) uç noktada **lokal olarak tespit edip engelleyebilirler**. Bu durum, bulut tabanlı analizin getireceği ağ gecikmesini (latency) ortadan kaldırarak kritik tehditlere anında müdahale edilmesini sağlar.



Merkezi Konsol (EDR Console) ve Veri Korelasyonu

Ajanların uç noktalardan gönderdiği devasa boyuttaki ham telemetri verisi, **EDR Console** (Merkezi EDR Konsolu) üzerinde toplanır. Konsol, sistemin "beyni" olarak işlev görür. Yüzlerce veya binlerce cihazdan gelen bu bağımsız veri parçacıkları, konsol üzerinde karmaşık mantıksal algoritmalar ve Makine Öğrenimi (Machine Learning) modelleri kullanılarak birbirine bağlanır; bu işleme **Correlation** (Korelasyon) denir.

Korelasyon süreci, ayrıca **Threat Intelligence** (Tehdit İstihbaratı - bilinen zararlı IP adresleri, dosya hash'leri ve saldırı tekniklerini içeren güncel veritabanı) ile çapraz sorgulamaya tabi tutulur. Eğer sistemin normal çalışma davranışından (baseline) bir sapma veya bilinen bir saldırı paterni eşleşirse, sistem bir **Alert** (Alarm) üretir.

Aşağıda merkezi EDR konsoluna bir ajan tarafından iletilmiş ve analiz motoru tarafından alarm haline getirilmiş örnek bir telemetri verisi yer almaktadır:

```
{
  "alert_id": "EDR-778-XR",
  "severity": "High",
  "endpoint": "FINANCE-PC-04",
  "user": "jdoe",
  "process_info": {
    "parent_process": "winword.exe",
    "child_process": "powershell.exe",
    "command_line": "powershell.exe -ExecutionPolicy Bypass -WindowStyle Hidden -EncodedCommand JABzAD0ATgB...",
    "action": "Process Creation"
  },
  "network_activity": {
```

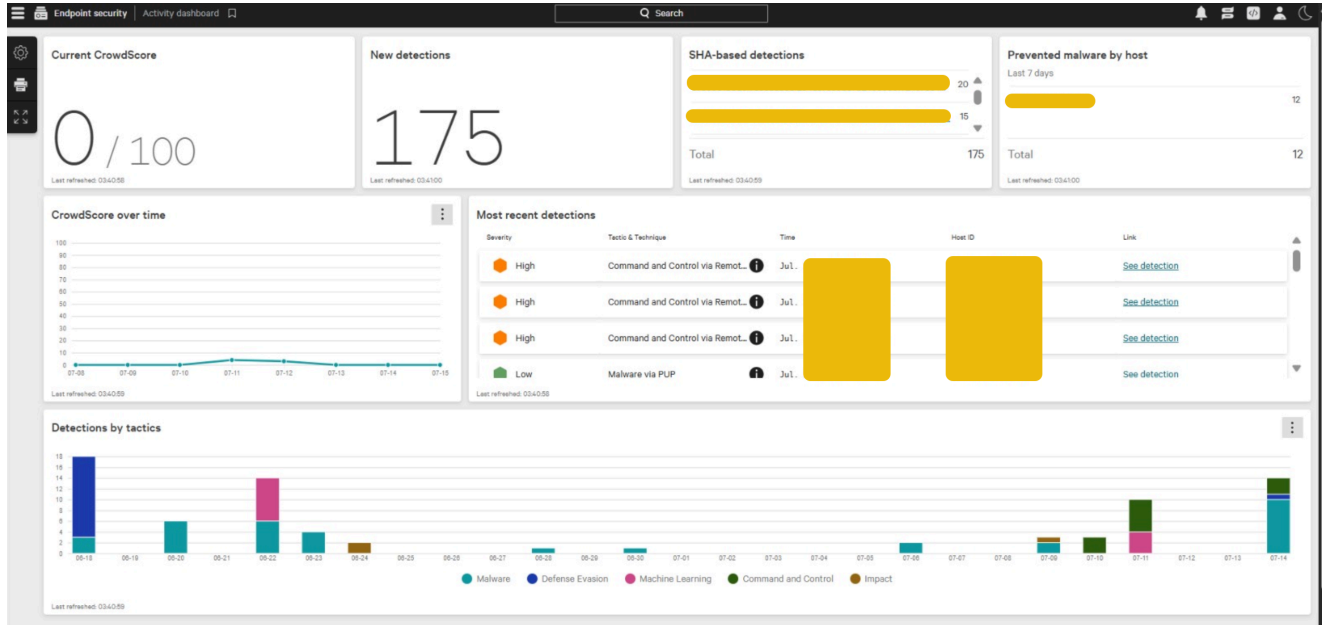


```
"destination_ip": "185.15.22.x",  
"destination_port": 443,  
"state": "ESTABLISHED"  
}  
}
```

Çıktı Analizi ve Mantıksal Derinlik: Yukarıdaki alarm çıktısı sıradan bir log değildir; bir saldırının anatomisini gösterir. `parent_process` olarak Microsoft Word (`winword.exe`) görülürken, bu sürecin bir `child_process` (alt süreç) olarak `powershell.exe`'yi başlattığı görülüyor. Normal şartlarda bir kelime işlemci uygulamasının sistem yönetim aracı olan PowerShell'i başlatması beklenmez. Ayrıca `command_line` parametrelerine baktığımızda, saldırganın PowerShell kısıtlamalarını aşmak için `-ExecutionPolicy Bypass` bayrağını, kullanıcıdan durumu gizlemek için `-WindowStyle Hidden` bayrağını ve tespitten kaçmak için kodları Base64 ile şifreleyerek `-EncodedCommand` bayrağını kullandığını anlıyoruz. Son aşamada ise bu şüpheli PowerShell süreci, dışarıdaki bir IP adresine HTTPS (443) üzerinden bağlantı kurmuştur. EDR konsolu, tüm bu ayırık olayları korele ederek tek bir "High" (Yüksek) seviyeli alarm üretmiştir.

Tespit Sonrası Süreç (Post-Detection) ve Triyaj

EDR konsolunda bir alarm düştüğünde, top **SOC** (Security Operations Center - Siber Güvenlik Operasyon Merkezi) analistine geçer. Analistin ilk görevi **Triage** (Trijaj - alarmları önceliklendirme ve ilk değerlendirme) yapmaktır. EDR, alarmları önem derecesine göre (Critical, High, Medium, Low, Informational) sınıflandırır. Analist, zaman kaybını önlemek için doğrudan "Critical" veya "High" seviyeli alarmları incelemeye başlar.



Analistin en kritik görevi, oluşan bu alarmın bir **False Positive** (Yanlış Pozitif - zararlı gibi görünen ama aslında meşru/zararsız olan sistem aktivitesi) mi yoksa bir **True Positive** (Gerçek Pozitif - gerçekten gerçekleşen bir siber saldırı/ihlal) mi olduğunu belirlemektir.

Eğer analiz sonucunda durum bir "True Positive" olarak değerlendirilirse, analist doğrudan EDR konsolu üzerinden uç noktaya fiziksel erişimi olmadan şu yanıt (Response) eylemlerini gerçekleştirebilir:

1. **Network Isolation (Ağ İzolasyonu):** İhlal edilen cihazın ağ bağlantısını keserek, zararlının ağ içinde yatay hareket (Lateral Movement) yapmasını engeller. Cihaz sadece EDR konsolu ile haberleşebilir durumda bırakılır.
2. **Process Termination (Süreç Sonlandırma):** Tespit edilen zararlı süreci (powershell.exe gibi) bellek üzerinden anında öldürür.
3. **File Quarantine (Dosya Karantinası):** Zararlı dosyayı şifreleyerek çalıştırılmaz hale getirir.

EDR'in Güvenlik Ekosistemindeki Yeri ve SIEM Entegrasyonu

DİKKAT: Kapsamlı görünürlüğüne rağmen EDR "her derde deva" bir çözüm (silver bullet) değildir. EDR yalnızca üzerinde ajan kurulu olan uç noktaların işletim sistemi seviyesindeki güvenliğinden sorumludur. Bir kurumun ağı, çok katmanlı bir savunma (Defense in Depth) mimarisi gerektirir.

Bu mimaride EDR; **Firewall** (Güvenlik Duvarı), **DLP** (Data Loss Prevention - Veri Sızıntısı Önleme sistemleri), **Email Security Gateways** (E-posta Güvenlik Ağ Geçitleri) ve **IAM** (Identity and Access Management - Kimlik ve Erişim Yönetimi) gibi diğer güvenlik bileşenleriyle birlikte çalışır.

Tüm bu farklı güvenlik çözümlerinden (EDR dahil) gelen loglar ve alarmlar, merkezi bir **SIEM** (Security Information and Event Management - Güvenlik Bilgileri ve Olay Yönetimi) sistemine yönlendirilir.

Neden SIEM kullanıyoruz? Çünkü EDR sadece uç noktayı görür. Eğer bir saldırgan güvenlik duvarını aşır, e-posta sunucusuna sızır, oradan bir uç noktaya sıçradıysa; analistin bu saldırının tam resmini (kill chain) görebilmesi için Güvenlik Duvarı loglarını, E-posta geçidi loglarını ve EDR telemetrisini aynı ekranda birleştirmesi gerekir. SIEM, tüm güvenlik ekosisteminin entegre edildiği nihai soruşturma ve korelasyon merkezidir.

EDR (Endpoint Detection and Response) Telemetrisi

Telemetry (Telemetri) Nedir?

Uç noktalara (endpoints) kurulan **EDR Ajanlarının (Agents)** işletim sistemi üzerinde toplayarak merkezi EDR konsoluna aktardığı muazzam veri bütününe **Telemetry (Telemetri)** adı verilir. Telemetri, bir uç noktanın siber güvenlik açısından "kara kutusu" (black box) niteliğindedir. Olası bir siber ihlal durumunda, saldırının tam olarak nasıl başladığını, hangi aşamalardan geçtiğini ve sistemde ne gibi değişikliklere yol açtığını tespit etmek (Root Cause Analysis - Kök Neden Analizi) için gereken yegane kanıt setidir.

Toplanan Telemetri Kategorileri ve Analitik Değeri

Bir işletim sisteminde arka planda saniyede binlerce meşru işlem gerçekleşir. Güvenlik analistlerinin en büyük handikabı, bu devasa veri yığını (noise/gürültü) içinden zararlı olanları (signal/sinyal) hatasız ayıklamaktır. Toplanan verinin kapsamı genişledikçe, EDR'ın ve analistin yapacağı analizlerin isabet oranı (True Positive) artar. Geleneksel tespit sistemlerinin ötesine geçen EDR, aşağıdaki kritik bileşenleri aralıksız loglar ve birbirleriyle korele eder:

Process Executions and Terminations (Süreç Yürütme ve Sonlandırma İşlemleri)

Sistemde aktif olarak çalışan ve beklemede olan (idle) tüm süreçlerin (processes) yaşam döngüsü izlenir. Bu telemetrinin en kritik noktası süreçlerin adını bilmek değil, süreçler arasındaki **Parent-Child Process (Ebeveyn-Çocuk Süreci)** ilişkilerini analiz etmektir.

- **Mantıksal Derinlik:** Bir zararlı yazılım genellikle sisteme meşru ve masum görünen bir uygulamanın altına saklanarak sızar. Örneğin, `winword.exe` (Microsoft Word) sürecinin altından bir `cmd.exe` veya `powershell.exe` sürecinin doğması (spawn edilmesi) son derece anormal bir ilişkidir. EDR bu telemetri sayesinde, kullanıcının ortalama belgesini açmasıyla tetiklenen bir **Payload (Saldırı Yüğü - hedefe ulaştığında asıl zararı veren, saldırganın amacını gerçekleştiren kod parçası)** yürütülmesini anında yakalar.

Network Connections (Ağ Bağlantıları)

Uç noktanın gerçekleştirdiği tüm gelen (inbound) ve giden (outbound) ağ bağlantıları izlenir. Hedef ve kaynak **IP adresleri**, kullanılan **Port numaraları** ve oturum süreleri veri tabanına işlenir.

- **Mantıksal Derinlik:** Tehdit aktörleri, ele geçirdikleri sistemin yönetimini sürdürmek için kendi **C2 (Command and Control - Komuta ve Kontrol) Sunucuları** ile düzenli iletişim (beaconing) kurmak zorundadır. Ağ telemetrisi sayesinde; alışılmadık portlardan yapılan dış bağlantılar, kuruma ait hassas verilerin dışarı çıkarıldığı **Data Exfiltration (Veri Sızdırma)** eylemleri veya saldırganın ağ içindeki diğer sunuculara sıçramaya çalıştığı **Lateral Movement (Yatay Hareket)** aktiviteleri hızlıca izole edilir.

Command Line Activity (Komut Satırı Aktiviteleri)

CMD, PowerShell veya diğer terminal kabukları (shells) üzerinden çalıştırılan her bir komut, aldığı argüman (parametre) zincirleriyle birlikte kaydedilir. Geleneksel antivirüs yazılımlarının kör noktalarından biri olan bellek içi (in-memory) aktiviteler burada açığa çıkar.

```
powershell.exe -NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -  
EncodedCommand JABzAD0ATgBLAHcALQBP...
```

- **Çıktı Analizi:** Yukarıdaki gibi bir telemetri logu yakalandığında EDR bunu sadece bir "PowerShell çalıştı" kaydı olarak görmez. Komuttaki parametreleri yorumlar:

- `-NoProfile` : Kullanıcı profillerini yüklemeyerek iz bırakmamaya ve hızlı çalışmaya yönelik bir parametre.
- `-ExecutionPolicy Bypass` : PowerShell'in varsayılan güvenlik kısıtlamalarını devre dışı bırakma çabası.
- `-WindowStyle Hidden` : İşlemi arka planda gizlice yürüterek kullanıcının ekranında bir pencere açılmasını engelleme (Stealth).
- `-EncodedCommand` : Komutların güvenlik çözümlerine takılmaması için **Obfuscation (Karmaşıklık - kodun statik imza tabanlı araçlar tarafından tespit edilmesini engellemek için anlamsız veya şifreli formata sokulması)** uygulandığını, burada Base64 kodlaması kullanıldığını gösterir.

Files and Folders Modifications (Dosya ve Klasör Değişiklikleri)

Sistem genelinde gerçekleşen dosya oluşturma (creation), değiştirme (modification), isimlendirme (renaming) ve silme (deletion) operasyonları loglanır.

- **Mantıksal Derinlik:** Saldırganlar ağ dışına çıkaracakları verileri arşivlemek için belirli klasörleri (**Data Staging**) kullanırlar. Veya bir Fidyeye Yazılımı (Ransomware), yüzlerce dosyanın içeriğini saniyeler içinde şifreleyerek uzantılarını değiştirir. Aynı zamanda, işletim sisteminin `%TEMP%` veya `C:\Users\Public` dizinlerine şüpheli `*.exe` veya `*.dll` dosyalarının düşürülmesi (Malicious File Dropping) eylemi, bu dosya izleme mekanizmasıyla derhal engellenecek bir indikatördür.

Registry Modifications (Kayıt Defteri Değişiklikleri)

Windows Kayıt Defteri (Registry), işletim sisteminin bel kemiğidir. EDR, kritik yapılandırma anahtarlarındaki (örn: `HKLM` ve `HKCU` kovanları) tüm değişiklikleri gözlemler.

- **Mantıksal Derinlik:** Başarılı bir sızma işleminin ardından saldırganın ilk önceliği **Persistence (Kalicilik - sistem yeniden başlatıldığında dahi zararlı yazılımın otomatik olarak çalışmaya devam etmesi)** sağlamaktır. Bunun için Windows'un `Run`, `RunOnce` anahtarlarına veya Servis (Service) yapılandırmalarına (örneğin var olan bir servisin yolunu değiştirme) müdahale edilir. EDR, bu kritik anahtarlardaki izinsiz modifikasyonları bir saldırı eylemi olarak algılar ve engeller.

Sentez: Davranışsal Analiz ve Olay Zincirinin Yeniden İnşası

ÖNEMLİ: Gelişmiş tehditler (APT - Advanced Persistent Threats), dikkat çekmemek için sistemin zaten sahip olduğu yasal ve güvenilir araçları kötüye kullanır (Bu tekniğe "Living off the Land - LotL" denir). Bu yüzden aktivitelerin tekil olarak değerlendirilmesi anlamsızdır.

Sıradan bir kullanıcının klasör ismini değiştirmesi veya CMD'yi açması meşrudur. Ancak karmaşık mantık ve Makine Öğrenimi (Machine Learning) algoritmalarıyla donatılmış EDR, bu verileri izole şekilde değil, **Korelasyon (Correlation)** ile yorumlar.

Analist, detaylı telemetri ekranını açtığında sadece bir dizi log görmez; **Root Cause (Kök Neden)** tespiti yapar ve tüm **Attack Timeline'ı (Saldırı Zaman Çizelgesi)** adım adım geriye doğru inşa eder: *"Bir Word belgesi açıldı -> Şüpheli PowerShell komutu tetiklendi -> C2 sunucusuna HTTPS isteği atıldı -> Zararlı kod belleğe (Memory) indirildi -> Registry'de kalıcılık sağlandı -> Klasörler şifrlenmeye başlandı."*

EDR'ı sektörde yeri doldurulamaz yapan özellik, sadece anomaliyi tespit etmesi değil, bu kusursuz kanıt zincirini analistin önüne getirebilmesidir.

EDR: Tespit ve Müdahale Yetenekleri (Detection and Response Capabilities)

Uç noktalardan (endpoints) toplanan ham telemetri verisinin (Telemetry) gerçek bir siber güvenlik değerine dönüşmesi, EDR (Endpoint Detection and Response) sisteminin bu veriyi nasıl analiz ettiğine ve tespit sonrası olaylara nasıl müdahale ettiğine bağlıdır. Bu doküman, modern bir EDR sisteminin arka planda çalışan gelişmiş tespit motorlarını ve bir SOC (Security Operations Center) analistinin elindeki müdahale cephaneliğini derinlemesine

incelemektedir.



Gelişmiş Tespit Mekanizmaları (Advanced Detection Techniques)

Ajanlar (agents) tarafından toplanıp merkezi konsola iletilen telemetri, basit bir log yığını değildir. EDR, bu veriyi anlamlandırmak için eşzamanlı çalışan çok katmanlı tespit teknikleri kullanır.

Davranışsal Tespit (Behavioral Detection) Geleneksel antivirüs çözümleri dosyaların statik imzalarına (hash değerleri) odaklanırken, gelişmiş tehdit aktörleri polimorfik (sürekli değişen) zararlılar yaratarak bu engeli aşarlar. EDR, dosyanın ne olduğuna değil, **ne yaptığına**

(davranışına) odaklanır. Bir zararlı yazılım, meşru sistem süreçlerini (Living off the Land) kullanarak kendini gizlemeye çalışsa bile EDR bu sıradışı etkileşimi yakalar.

```
# EDR Süreç Ağacı (Process Tree) Simülasyonu
[+] explorer.exe (PID: 1024) - Normal Kullanıcı Oturumu
└─ [+] winword.exe (PID: 2048) - Kullanıcının açtığı Word belgesi
    └─ [!] powershell.exe (PID: 3192) - "-ExecutionPolicy Bypass -enc
        JABz..."
```

Analitik Yorum: Yukarıdaki süreç ağacında, meşru bir ofis uygulaması olan **winword.exe**'nin bir sistem yönetim kabuğu olan **powershell.exe**'yi başlatması (spawn etmesi) son derece anormal bir Ebeveyn-Çocuk (Parent-Child) ilişkisidir. EDR, çalıştırılan scriptin içeriğini (imzasını) bilmeseydi bile, sırf bu *davranış* modelinden dolayı süreci anında zararlı olarak işaretler (flag).

Anomali Tespiti (Anomaly Detection) EDR çözümleri, zaman içinde uç noktanın ve kullanıcının normal çalışma profilini (Baseline) öğrenir. Bu baseline'dan sapan her türlü olağandışı aktivite anomali olarak değerlendirilir. Saldırganlar sisteme sızdıklarında, kalıcılık sağlamak veya veri toplamak için kaçınılmaz olarak bu normal çerçevenin dışına çıkarlar.

ÖNEMLİ: Anomali tespiti, doğası gereği False Positive (Yanlış Pozitif) alarmlar üretebilir. Sistem yöneticisinin meşru bir bakım çalışması da anomali olarak algılanabilir. Ancak EDR'ın sunduğu tam bağlam (full context) sayesinde analist, olayın meşruiyetini hızla doğrulayabilir.

Kod snippet'i

```
HKCU\Software\Microsoft\Windows\CurrentVersion\Run
Değer Adı: "WindowsUpdater"
Veri: "C:\Users\Public\Temp\svchost.exe"
```

Analitik Yorum: Bir sürecin, yukarıdaki otomatik başlatma (auto-start) kayıt defteri (Registry) anahtarını değiştirmesi sıradan bir uç nokta için tipik bir davranış değildir. Özellikle çalıştırılmak istenen dosyanın **C:\Users\Public\Temp** gibi geçici ve herkesin yazabildiği bir dizinde olması ve meşru sistem dosyası adını (**svchost.exe**) taklit etmesi kritik bir anomalidir.

İhlal Göstergesi (IOC) Eşleştirmesi (IOC Matching) Tehdit İstihbaratı (Threat Intelligence), EDR sistemlerinin dış dünyayla bağlantısıdır. Zero-day (Sıfırıncı gün) zafiyetleri hariç, çoğu saldırının IP adresi, alan adı (domain), dosya hash'i veya spesifik URL'ler gibi bilinen İhlal Göstergeleri (IOC - Indicators of Compromise) vardır. EDR, uç noktada gerçekleşen her aktiviteyi devasa Tehdit İstihbaratı akışlarıyla (feeds) anlık olarak karşılaştırır. Kullanıcı bir dosya indirdiğinde ve bu dosya çalıştırılabilir (.exe) dosya bıraktığında (drop ettiğinde), EDR bu dosyanın hash değerini sorgular. Eğer bu hash bilinen bir tehdit aktörüne aitse, aktivite saniyeler içinde bloklanır.

MITRE ATT&CK Haritalandırması (MITRE ATT&CK Mapping) Bir analist için en büyük zorluk, gelen alarmin saldırı zincirinin (Kill Chain) neresinde olduğunu anlamaktır. Modern EDR'lar, yakaladıkları her şüpheli aktiviteyi doğrudan MITRE ATT&CK çerçevesindeki Taktik (Tactic - Saldırganın amacı) ve Teknik (Technique - Bu amacı nasıl gerçekleştirdiği) ile eşleştirir.

Eğer EDR şüpheli bir zamanlanmış görev (Scheduled Task) oluşturulduğunu tespit ederse, alarmı şu şekilde etiketler:

- **Taktik:** Persistence (Kalıcılık - Sistem yeniden başlasa bile erişimi koruma)
- **Teknik:** Scheduled Task/Job (Zamanlanmış Görev/İş) Bu standartlaştırılmış dil, SOC ekibinin olaya yaklaşım stratejisini belirlemede hayati rol oynar.

Makine Öğrenimi Algoritmaları (Machine Learning Algorithms) Gelişmiş tehdit aktörleri, tespitlerden kaçmak için kodlarını sürekli şifreler (obfuscation) veya araçlarını belleğe enjekte ederek çalıştırır. Makine Öğrenimi (ML) modelleri, milyonlarca normal ve zararlı davranış setiyle eğitilmiştir. Bireysel olarak incelendiğinde tamamen meşru görünen (örneğin WMI sorguları yapmak, PowerShell ile dosya okumak) bir dizi komut, bir araya geldiğinde ML motoru tarafından karmaşık bir saldırı paterni olarak tespit edilir. Özellikle diske dosya yazmadan doğrudan RAM üzerinde çalışan Dosyasız Zararlı Yazılımlar (Fileless Malware) ve çok aşamalı sızma girişimleri, bu ML algoritmalarının korelasyon yeteneği sayesinde yakalanır.

Müdahale Kapasitesi ve Yanıt Seçenekleri (Response Mechanisms)

Tespit aşaması başarılı olduktan sonra, tehdidin etkisiz hale getirilmesi (containment & eradication) gerekir. EDR'lar bilinen tehditleri otomatik olarak engellemek üzere yapılandırılabilir (Policy-based blocking); ancak gerçek güç, bir güvenlik analistinin konsol üzerinden manuel olarak gerçekleştirebileceği müdahale seçeneklerinde yatar.

Ağ İzolasyonu (Isolate Host) Zararlı bir aktivite tespit edildiğinde atılacak en kritik ilk adım, ilgili uç noktanın ağ ile olan iletişimini tamamen kesmektir. Ransomware (Fidye Yazılımı) gibi ağ içinde hızla yayılan (Lateral Movement - Yatay Hareket) saldırılar, tek bir enfekte cihazdan tüm ağa sıçrayabilir. Host İzole edildiğinde, EDR ajanı işletim sistemi seviyesindeki güvenlik duvarı kurallarını ezerek cihazın internet ve yerel ağ erişimini keser. Cihaz **SADECE** EDR yönetim konsolu ile haberleşebilecek şekilde (genellikle spesifik bir IP ve port üzerinden) kilitlenir.

Süreci Sonlandırma (Terminate Process) Her olay, cihazın tamamen ağdan koparılmasını gerektirmez (veya buna imkan tanımaz). Örneğin, kurumun kritik veritabanı sunucusunda (Core Business Operations) bir izolasyon yapmak, zararlı yazılımın vereceğinden daha büyük bir iş kesintisine (downtime) yol açabilir. Bu gibi durumlarda analist, EDR üzerinden spesifik olarak tespit edilen zararlı süreci bellekten düşürebilir (Kill Process).

DİKKAT: Meşru sistem süreçlerini sonlandırmak işletim sisteminin çökmesine (Blue Screen of Death - BSOD) neden olabilir. Ayrıca, zararlı sürecin bir ebeveyn süreci (parent) tarafından sürekli yeniden başlatılma ihtimaline karşı analistin tüm süreç ağacını inceleyerek kök süreci sonlandırması gerekir.

Karantina (Quarantine) Uç noktaya inen zararlı bir dosya tespit edildiğinde, dosya karantinaya alınır. Karantina işlemi basit bir "silme" işlemi değildir. EDR ajanı, dosyayı diskin korumalı ve izole edilmiş (genellikle şifrelenmiş) bir bölgesine taşır, dosyanın çalıştırılma yetkilerini (Execution) iptal eder. Bu sayede tehdit etkisiz hale getirilirken, dosya daha sonra analistlerin Tersine Mühendislik (Reverse Engineering) veya detaylı analiz yapabilmesi için muhafaza edilmiş olur.

Uzaktan Erişim (Remote Access - RTR) Bazı karmaşık olaylarda, standart "izole et/karantinaya al" butonları yetersiz kalır. Modern EDR sistemleri (örn. CrowdStrike Falcon RTR - Real Time Response), analiste uç nokta üzerinde yüksek yetkili (genellikle **NT AUTHORITY\SYSTEM** yetkileriyle) ve gizli bir komut satırı arayüzü (Shell) sağlar. Kullanıcının haberi olmadan çalışan bu arka kapı sayesinde analistler:

- Zararlı yazılımın sildiği kayıt defteri anahtarlarını düzeltebilir,
- Özel PowerShell betikleri çalıştırabilir,
- Gizlenmiş dosyaları tespit edebilir veya sisteme özel yamalar uygulayabilir.

```
# EDR Remote Access (RTR) Üzerinden Tipik Bir Analist Müdahalesi
> runscript -CloudFile="Kill_Malicious_Service.ps1"
> get "C:\Users\Public\Temp\suspicious_payload.dll"
```

Yukarıdaki simülasyonda analist, uzaktan erişim kabuğu ile merkezi bir scripti enfekte makinede çalıştırıyor ve analize devam etmek için zararlı payload'u kendi makinesine çekiyor.

Adli Bilişim Veri Toplama (Artefacts Collection) Kapsamlı bir inceleme (Forensic Investigation) veya yasal mercilere sunulacak raporlamalar için, uç noktadan kritik dijital delillerin (Artefacts) toplanması gerekir. EDR üzerinden fiziksel erişim olmadan çekilebilecek hayati kalıntılar şunlardır:

- **Memory Dump (Bellek Dökümü):** Sistem RAM'inin tam veya kısmi kopyasıdır. Diske yazılmamış (Fileless) zararlı yazılımların, şifreleme anahtarlarının ve ağ bağlantılarının tespiti için altın değerindedir.
- **Event Logs (Olay Günlükleri):** Windows Event Viewer logları (.evtx). Kimlik doğrulama hataları, servis başlangıçları ve sistem hatalarını kronolojik olarak gösterir.
- **Registry Hives (Kayıt Defteri Kovanları):** SAM (Şifre hashleri), SYSTEM ve SOFTWARE kovanları saldırganın sistemde yaptığı kalıcı değişiklikleri ortaya çıkarır.
- **Specific Folder Contents (Spesifik Klasör İçerikleri):** Prefetch klasörü (hangi .exe dosyasının ne zaman çalıştığı), Temp dizinleri veya saldırganın araçlarını

barındırdığından şüphelenilen dizinlerin (Staging areas) içeriği kanıt bütünlüğü (Chain of Custody) bozulmadan elde edilir.